Lab 3b: Advanced Cybersecurity Risk Quantification

SecureBank Financial – SecureMobile Banking Platform

Item	Detail
Name	Oluwatosin Olajubu
Registration number	C11/26/CGRCE/217602
Role in scenario	Lead GRC Analyst, SecureBank Financial
Reviewers	CISO and CFO
Date	27 October 2026
Companion file	GRC_Lab3b_Risk_Quantification_Workbook.xlsx (editable, all formulas live)

How to read this report: Every number below is calculated in the companion workbook with live formulas. Each calculation here shows the formula, the numbers substituted into it, and the result, so it can be repeated on a calculator. Figures taken from the lab brief are called supplied; anything the brief does not state is called an assumption and is listed in Section 7.

Editable charts: Every chart in this report is a native Word chart, not a picture. Right-click a chart and choose Edit Data: Word opens the embedded calculation workbook, where all formulas are live, and the chart updates when the inputs change. The heat map is an ordinary Word table.

1. Executive summary

SecureMobile carries an expected loss of $35,000,000 per year across the three critical findings. The database injection finding alone accounts for 89.3% of it ($31,250,000 per year), so it is the Critical priority.

Buying all three controls costs $700,000 up front plus $105,000 a year to maintain. At full effect they cut the expected annual loss by $26,962,500 (77.0%), leaving $8,037,500. The WAF and MFA each pay back in under a month. The API Security Gateway pays back in about 204 days and is the marginal control: its result depends most on the assumptions (Section 5.3).

Recommendation: implement all three, in the order WAF (live by day 30), then MFA and API Security Gateway (live by day 90). The one-page dashboard is in Section 6.

2. Supplied figures and assumptions

2.1 Supplied by the lab brief

Item	Finding 1: API Auth Bypass	Finding 2: Database Injection	Finding 3: Session Hijacking
Exploit probability	15%	25%	40%
Impact driver A	Max single incident loss $5,000,000	Records at risk 500,000	Accounts at risk 5,000
Impact driver B	(none given)	Cost per record $250	Average loss per account $1,500
System Affected	Transaction processing system	Customer Database	User Session
Other	Detection time 48 hours	–	–

Control	Initial cost	Effectiveness	Annual maintenance
Advanced API Security Gateway	$350,000	90% reduction in API vulnerabilities	$50,000
Web Application Firewall (WAF)	$150,000	75% reduction in web vulnerabilities	$25,000
MFA Enhancement	$200,000	95% reduction in account takeover	$30,000

System context (500,000 customers, $2,500 average transaction, 50,000 daily transactions) is not used in the ALE because the brief gives loss figures for each finding directly.

2.2 Key assumptions (full register in Section 7)

- ARO is the supplied exploit probability, read as the chance of one exploitation event per year (A-01).
- Finding 1 SLE is the supplied maximum single-incident loss, one incident per event; the 48-hour detection time is context only (A-02).
- Findings 2 and 3 assume the full at-risk population is compromised in one event (A-03, A-04).
- Mapping: API Gateway → Finding 1, WAF → Finding 2, MFA → Finding 3, with no cross-benefit (A-05).
- Effectiveness reduces the finding's ALE proportionally; costs are not discounted; ROI horizon is 3 years (A-06 to A-09).

3. Phase 1 – Risk exposure calculation

Task 1: SLE, ARO and ALE – worked step by step

Formulas: SLE = driver A × driver B. ARO = supplied exploit probability. ALE = SLE × ARO.

F1 – API Authentication Bypass

- SLE = 5,000,000 × 1 = $5,000,000 (Maximum single incident loss × Incidents per loss event)
- ARO = 15% = 0.15 incidents per year
- ALE = $5,000,000 × 0.15 = $750,000 per year

F2 – Database Injection Vulnerability

- SLE = 500,000 × 250 = $125,000,000 (Records at risk × Cost per record)
- ARO = 25% = 0.25 incidents per year
- ALE = $125,000,000 × 0.25 = $31,250,000 per year

F3 – Session Hijacking

- SLE = 5,000 × 1,500 = $7,500,000 (Accounts at risk × Average loss per account)
- ARO = 40% = 0.4 incidents per year
- ALE = $7,500,000 × 0.4 = $3,000,000 per year

Total ALE = $750,000 + $31,250,000 + $3,000,000 = $35,000,000 per year.

Task 2: Risk prioritisation matrix

ID	Vulnerability	SLE	ARO	ALE / year	ALE rank	Prob. band	Impact band	Score P×I	Heat rating	Priority
F1	API Authentication Bypass	$5,000,000	15%	$750,000	3	Medium	Medium	4	Medium	Medium
F2	Database Injection Vulnerability	$125,000,000	25%	$31,250,000	1	Medium	High	6	High	Critical
F3	Session Hijacking	$7,500,000	40%	$3,000,000	2	High	Medium	6	High	High

Bands (assumption A-10): probability High ≥ 30%, Medium ≥ 10%; impact (SLE) High ≥ $10M, Medium ≥ $1M; score = P × I with Low = 1, Medium = 2, High = 3 (score ≥ 6 High, 3-4 Medium). Priority level uses ALE: Critical ≥ $10M, High ≥ $1M, Medium ≥ $100k.

Task 3: Risk visualisations

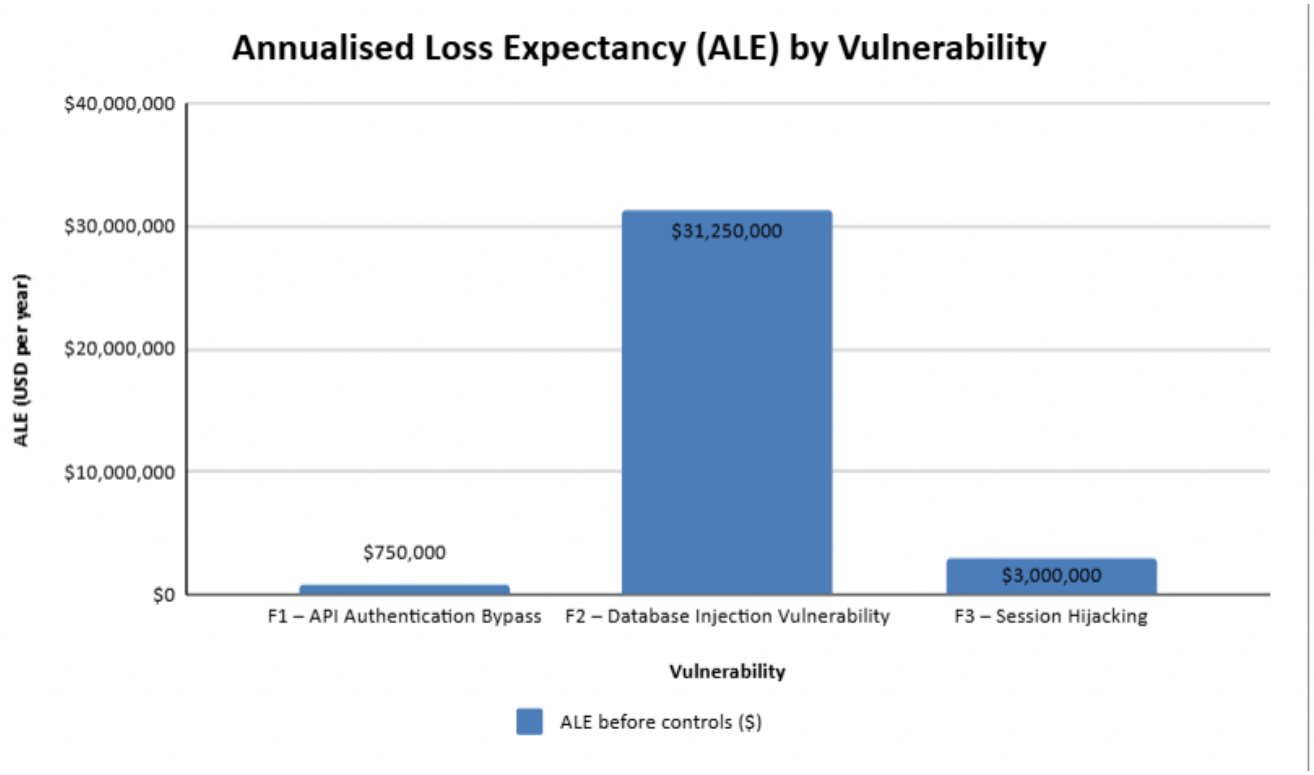


Figure 1: ALE per vulnerability, with the SLE × ARO working labelled on each bar.

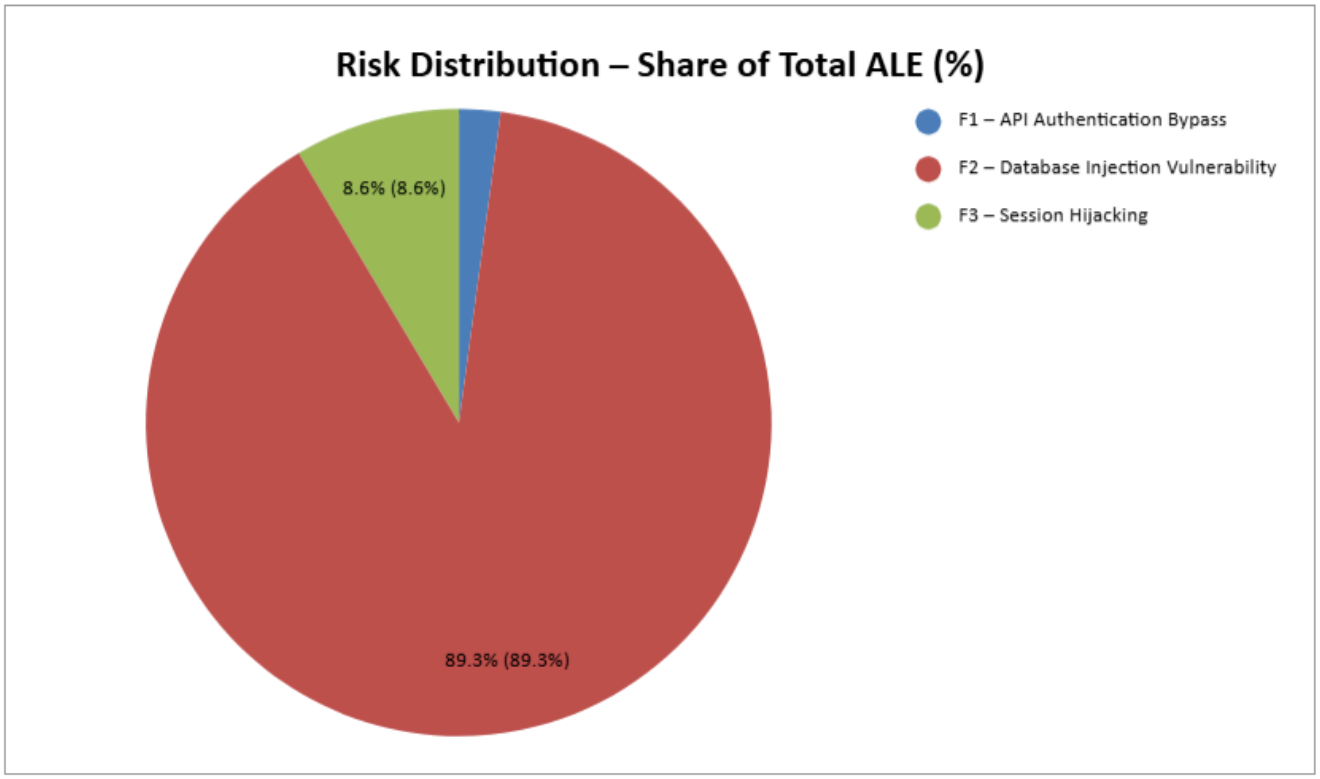


Figure 2: Share of total ALE. Finding 2 dominates the exposure.

Probability-impact heat map (cells show which findings fall in each band)

Impact (SLE) ↓ | Probability (ARO) →	Low (< 10%)	Medium (10% to < 30%)	High (≥ 30%)
High (SLE ≥ $10,000,000)		F2	
Medium ($1,000,000 to < $10,000,000)		F1	F3
Low (SLE < $1,000,000)			

Cell colour = risk score (probability score × impact score): red ≥ 6, amber 3-4, green ≤ 2. F1 = API Authentication Bypass, F2 = Database Injection, F3 = Session Hijacking.

Figure 3: Probability-impact heat map (editable table). F2 is the highest-impact finding; F3 is the most likely.

4. Phase 2 – Control evaluation

Task 4: Cost-benefit analysis – step by step

Each step uses the steps above it. Read down a column to follow one control.

Step	Calculation	API Security Gateway	WAF	MFA	All 3 controls
1 Baseline ALE ($/yr)	ALE of the finding addressed (from Risk_Calc)	$750,000	$31,250,000	$3,000,000	$35,000,000
2 Effectiveness (%)	Supplied in brief	90%	75%	95%	77.0%
3 Annual risk reduction ($/yr)	Step 1 × Step 2	$675,000	$23,437,500	$2,850,000	$26,962,500
4 Residual ALE ($/yr)	Step 1 − Step 3	$75,000	$7,812,500	$150,000	$8,037,500
5 Initial investment ($)	Supplied in brief	$350,000	$150,000	$200,000	$700,000
6 Annual maintenance ($/yr)	Supplied in brief	$50,000	$25,000	$30,000	$105,000
7 Year-1 total cost ($)	Step 5 + Step 6	$400,000	$175,000	$230,000	$805,000
8 Year-1 net benefit ($)	Step 3 − Step 7	$275,000	$23,262,500	$2,620,000	$26,157,500
9 Year-1 ROI (%)	Step 8 ÷ Step 7	68.8%	13,292.9%	1,139.1%	3,249.4%
10 3-year total cost ($)	Step 5 + (Step 6 × years)	$500,000	$225,000	$290,000	$1,015,000
11 3-year risk reduction ($)	Step 3 × years	$2,025,000	$70,312,500	$8,550,000	$80,887,500
12 3-year net benefit ($)	Step 11 − Step 10	$1,525,000	$70,087,500	$8,260,000	$79,872,500
13 3-year ROI (%)	Step 12 ÷ Step 10	305.0%	31,150.0%	2,848.3%	7,869.2%
14 Payback period (years)	Step 5 ÷ (Step 3 − Step 6)	0.560	0.006	0.071	0.026
15 Payback period (months)	Step 14 × 12	6.7	0.1	0.9	0.3
16 Payback period (days)	Step 14 × 365	204.4	2.3	25.9	9.5
Implementation priority (1 = first)	Rank of Step 3 (largest risk reduction first)	3	1	2	
Recommendation	Implement if payback ≤ max payback AND 3-year ROI ≥ minimum (Inputs B29, B30)	IMPLEMENT	IMPLEMENT	IMPLEMENT	All 3 justified

Substituted working (numbers written into each formula)

Step 3 – risk reduction

- **API Security Gateway:** $750,000 × 90% = $675,000
- **WAF:** $31,250,000 × 75% = $23,437,500
- **MFA:** $3,000,000 × 95% = $2,850,000

Step 9 – Year-1 ROI

- **API Security Gateway:** ($675,000 − $400,000) ÷ $400,000 = 68.8%
- **WAF:** ($23,437,500 − $175,000) ÷ $175,000 = 13,292.9%
- **MFA:** ($2,850,000 − $230,000) ÷ $230,000 = 1,139.1%

Step 13 – 3-year ROI

- **API Security Gateway:** ($2,025,000 − $500,000) ÷ $500,000 = 305.0%
- **WAF:** ($70,312,500 − $225,000) ÷ $225,000 = 31,150.0%
- **MFA:** ($8,550,000 − $290,000) ÷ $290,000 = 2,848.3%

Step 14 – payback

- **API Security Gateway:** $350,000 ÷ ($675,000 − $50,000) = 0.560 years = 204.4 days
- **WAF:** $150,000 ÷ ($23,437,500 − $25,000) = 0.006 years = 2.3 days
- **MFA:** $200,000 ÷ ($2,850,000 − $30,000) = 0.071 years = 25.9 days

Interpretation. The WAF protects the largest exposure at the smallest cost, so its ROI is extreme and its payback is about two days. Large ROI figures here come from the size of the Finding 2 ALE, not from the WAF's price; Section 5.3 tests how far that ALE can fall before the WAF stops paying back.

Task 5: Control selection analysis

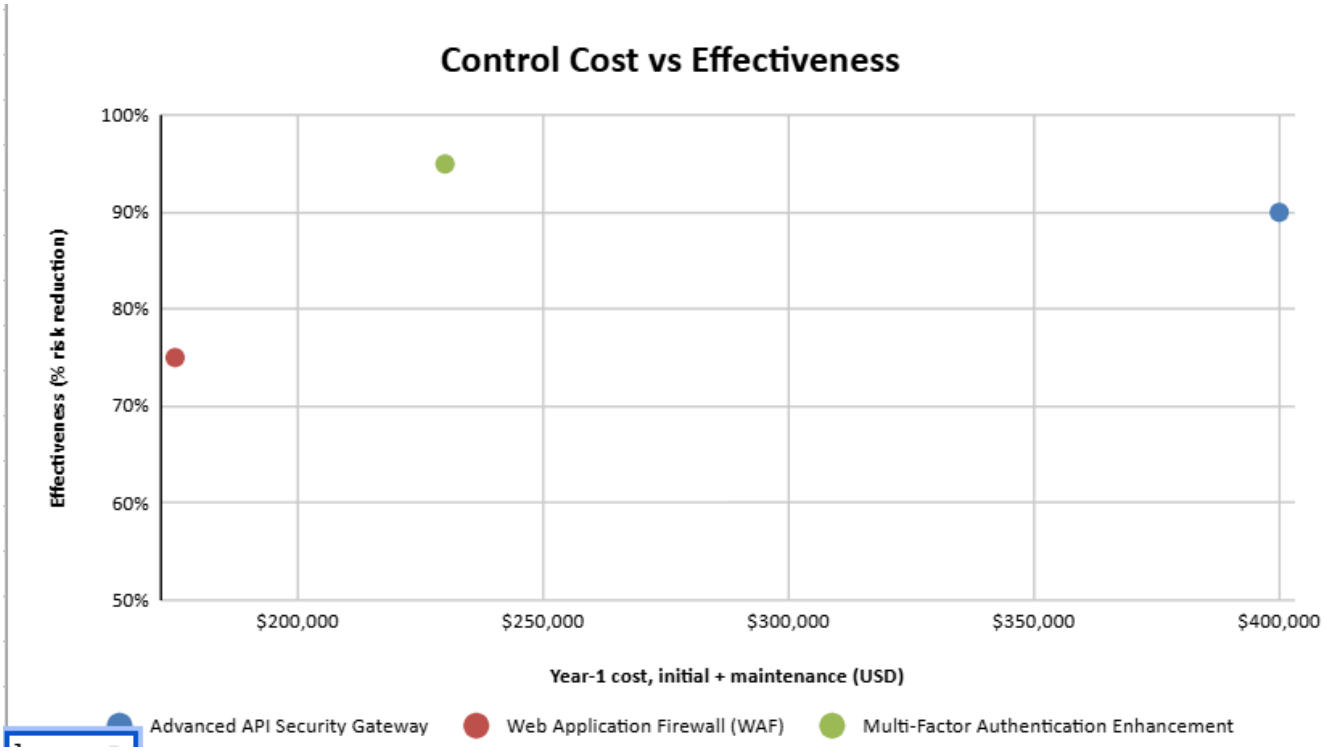


Figure 4: Control cost versus effectiveness. Marker size shows annual risk reduction in dollars.

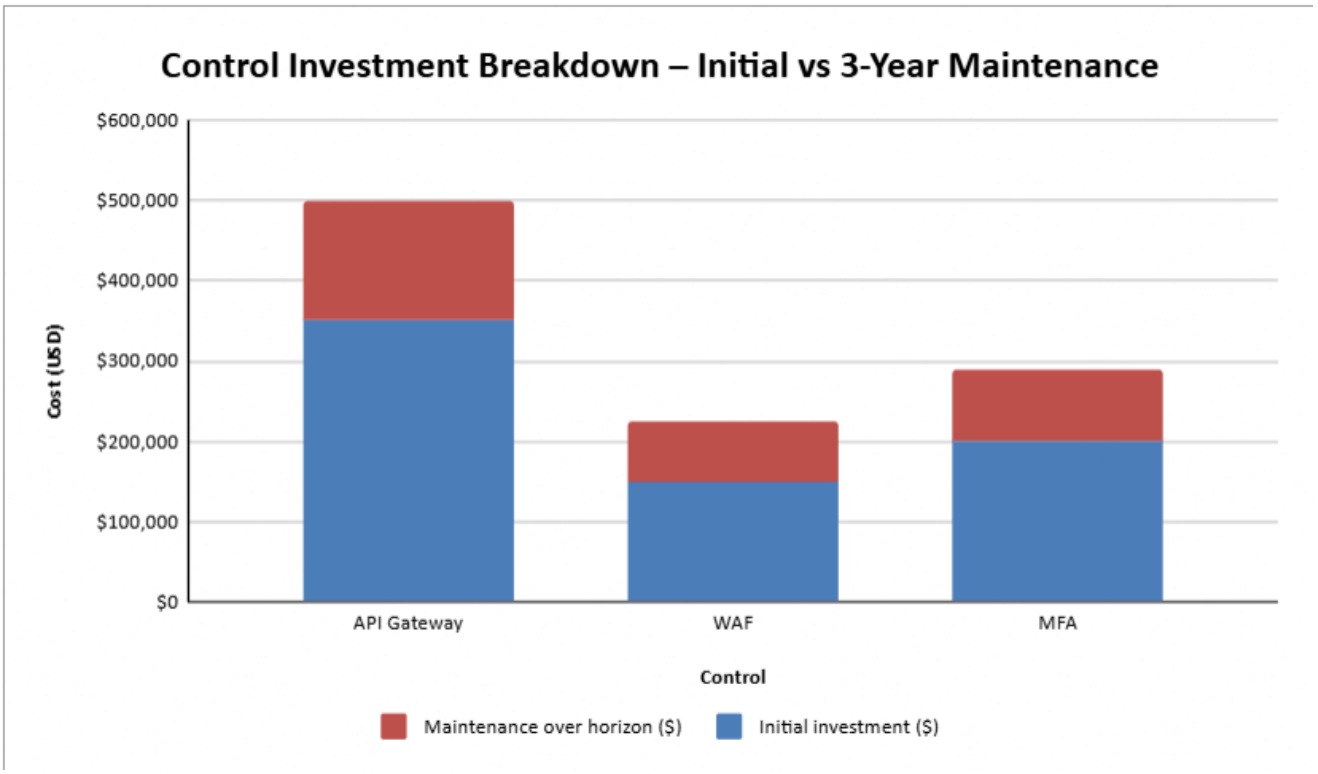


Figure 5: Year-1 ROI by control (log scale, because WAF ROI is about 190 times the API Gateway ROI).

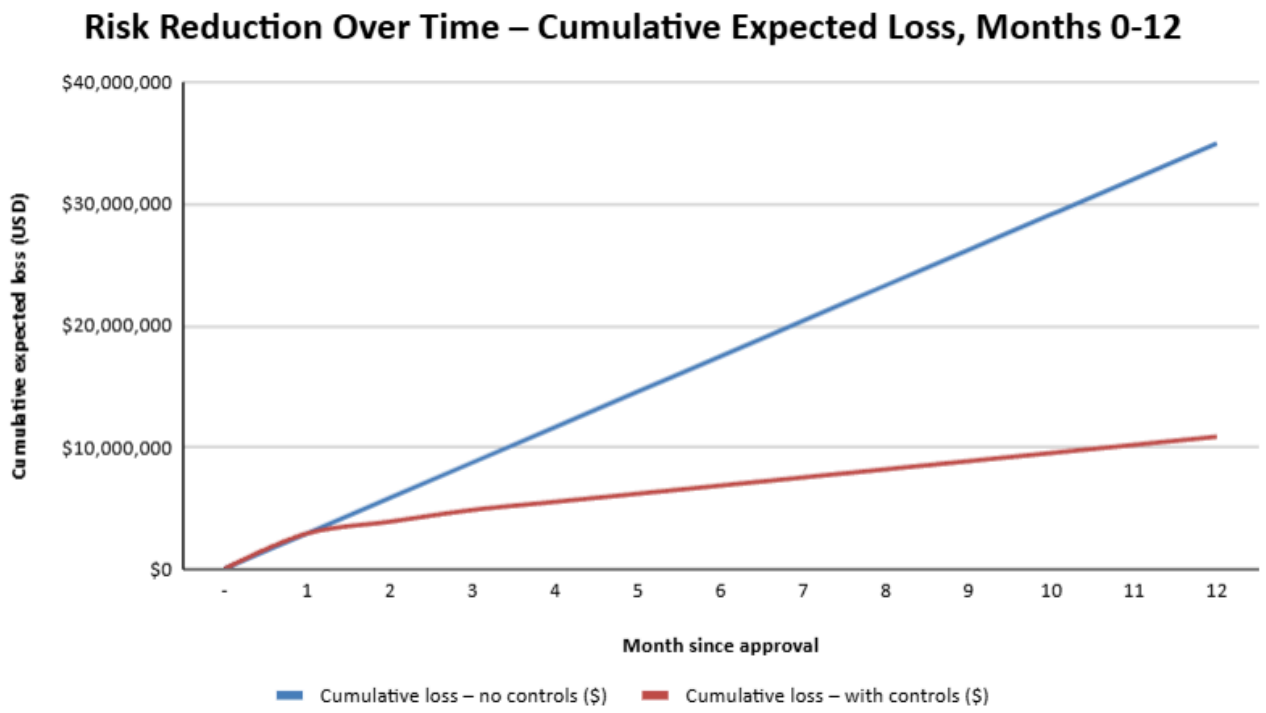
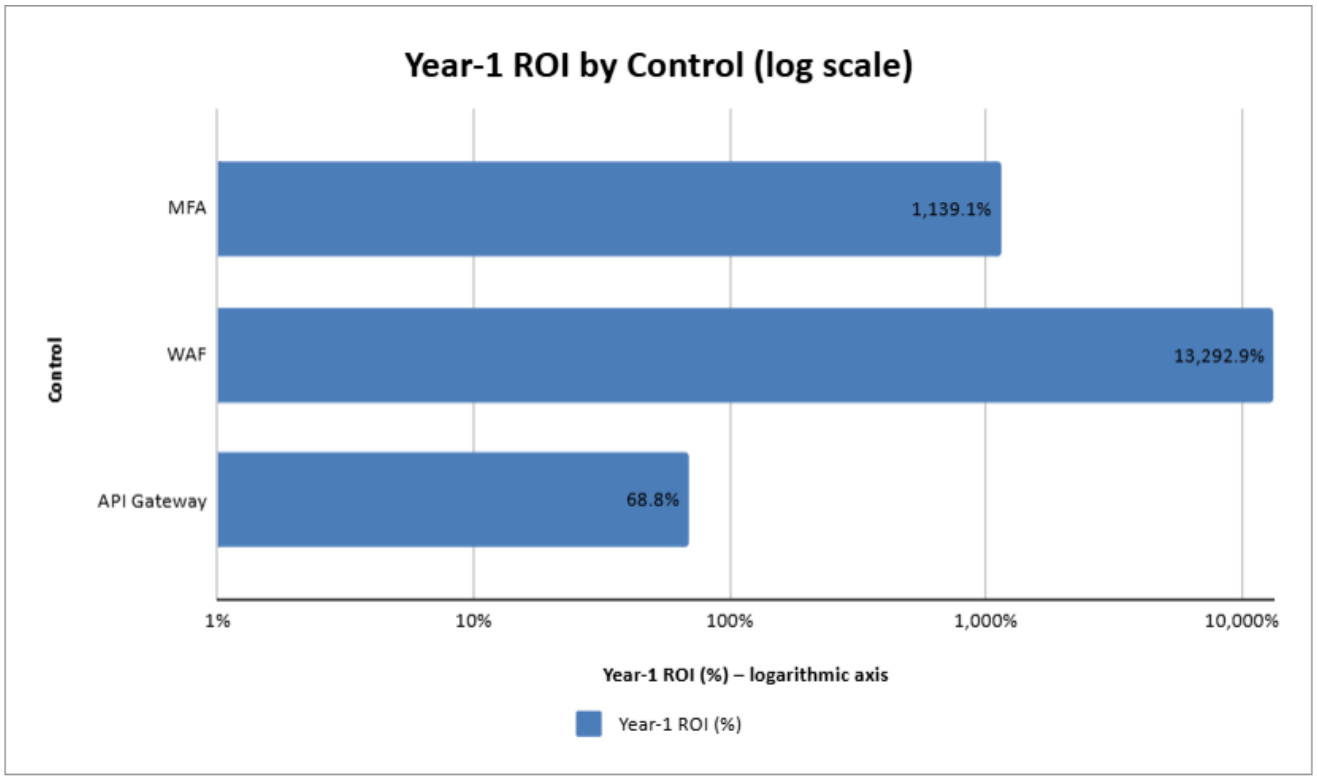


Figure 6: Cumulative expected loss over 12 months with and without the phased controls.

Timeline model: monthly expected loss = ALE ÷ 12 × (1 − effectiveness × live flag). A control protects from the month after its go-live month. Go-live months come from the Gantt plan: WAF month 1, MFA month 3, API Gateway month 3.

Year-1 figure (phased roll-out)	Amount
Year-1 expected loss with NO controls	$35,000,000
Year-1 expected loss WITH phased controls	$10,871,875
Year-1 loss avoided (phased roll-out)	$24,128,125
Year-1 control spend (initial + maintenance after go-live)	$782,917
Year-1 net benefit after control spend	$23,345,208
Steady-state annual risk reduction (Control_Analysis, once all controls are live)	$26,962,500

Year-1 avoided loss is lower than the steady-state reduction of $26,962,500 because the controls only go live on days 30 and 90.



5. Bonus – combined risk-control view, budget optimisation and sensitivity

5.1 Current exposure versus residual risk

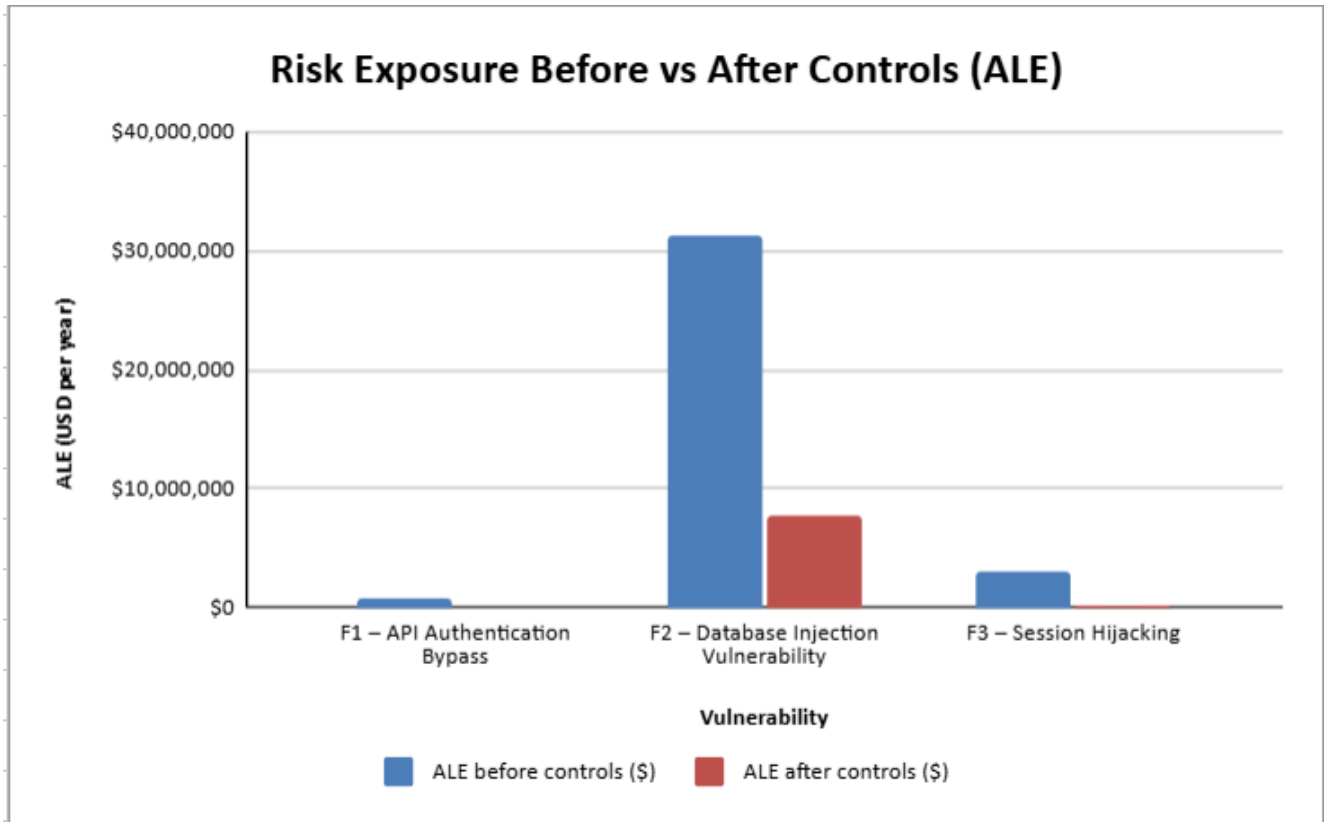


Figure 7: ALE before and after controls for each vulnerability. Residual ALE = baseline ALE × (1 − effectiveness).

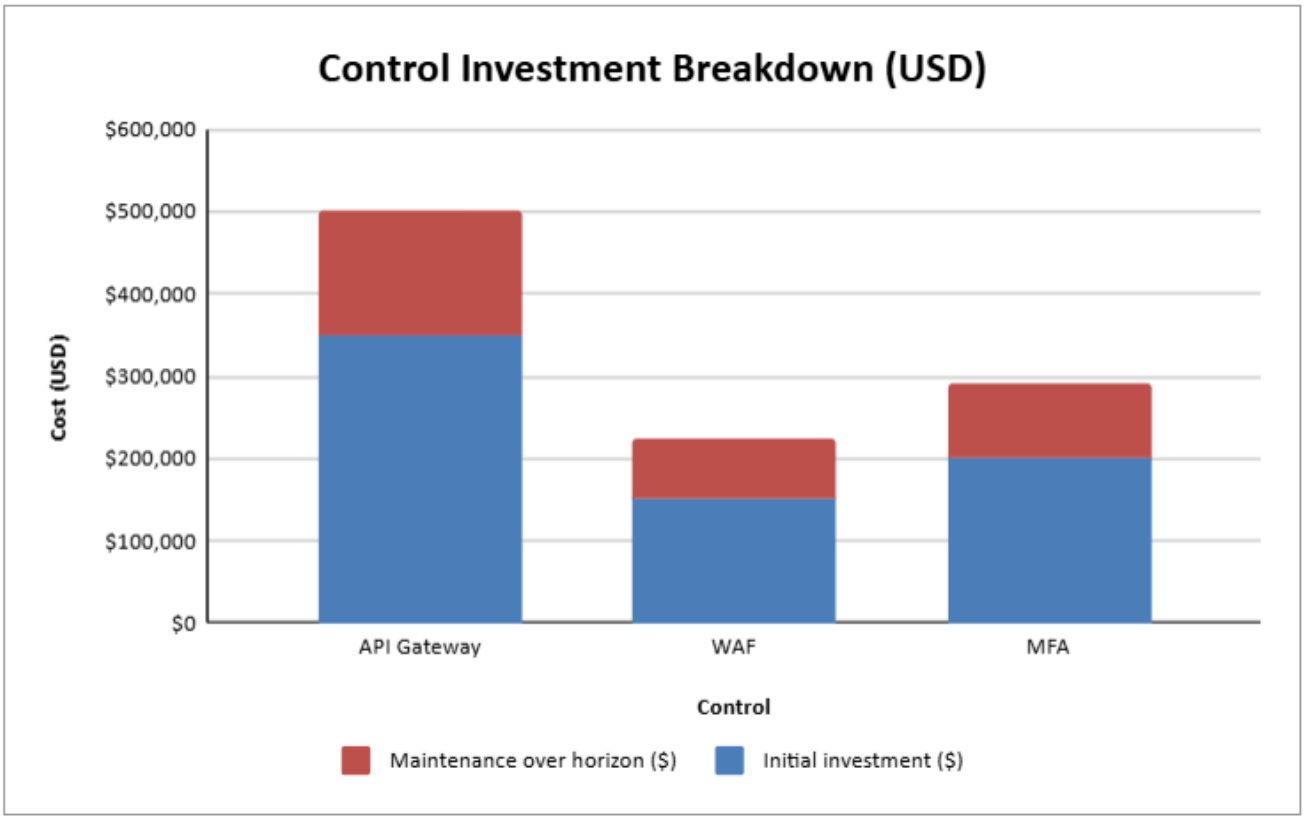


Figure 8: Control investment breakdown – initial cost and three years of maintenance.

5.2 Optimal selection under a capital budget

All 8 combinations of the three controls were tested; for each budget the feasible combination with the largest annual risk reduction is shown (capital cost only, assumption A-14).

Capital budget	Best combination	Capital used	Annual risk reduction	Residual ALE	Risk reduced
$150,000	WAF	$150,000	$23,437,500	$11,562,500	67.0%
$350,000	WAF + MFA	$350,000	$26,287,500	$8,712,500	75.1%
$500,000	WAF + MFA	$350,000	$26,287,500	$8,712,500	75.1%
$700,000	API Gateway + WAF + MFA	$700,000	$26,962,500	$8,037,500	77.0%

With a $150,000 budget the WAF alone removes about 67% of total ALE. Adding MFA ($350,000 total) lifts that to 75%. The API Gateway is only added when the budget reaches $700,000, because it buys the least risk reduction per dollar.

5.3 Sensitivity – how wrong can the assumptions be?

Break-even baseline ALE = Year-1 cost ÷ effectiveness. Below this ALE a control's Year-1 benefit is smaller than its Year-1 cost.

Control	Year-1 cost	Effectiveness	Break-even ALE	Modelled ALE	Headroom
Advanced API Security Gateway	$400,000	90%	$444,444	$750,000	1.7x
Web Application Firewall (WAF)	$175,000	75%	$233,333	$31,250,000	133.9x
Multi-Factor Authentication Enhancement	$230,000	95%	$242,105	$3,000,000	12.4x

The WAF stays justified even if the database ALE were only 0.75% of the modelled value. The API Gateway has only 1.7 times headroom: if the loss per event fell to $3 million at a 10% probability, its Year-1 ROI would turn negative. The Sensitivity sheet in the workbook holds the full what-if tables.

6. Phase 3 – Executive briefing package

Task 6: One-page executive dashboard

Executive Risk Dashboard – SecureMobile Banking Platform

Prepared by: Oluwatosin Olajubu | Registration no.: C11/26/CGRCE/217602 | Date: 27 October 2026 | For: CISO and CFO

Baseline ALE ($/yr)	Residual ALE after controls ($/yr)	Annual risk reduction ($/yr)	Risk reduction (%)	Total initial investment ($)	Portfolio Year-1 ROI (%)	Portfolio payback (days)
$35,000,000	$8,037,500	$26,962,500	77.0%	$700,000	3,249.4%	9.5

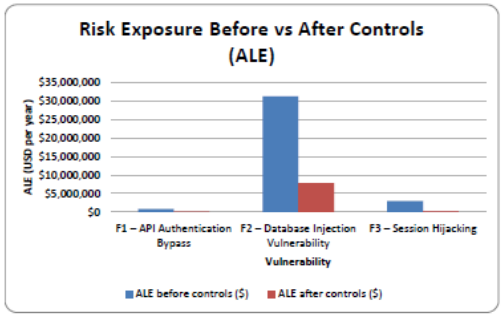
Top 3 risks with financial impact (ranked by ALE)

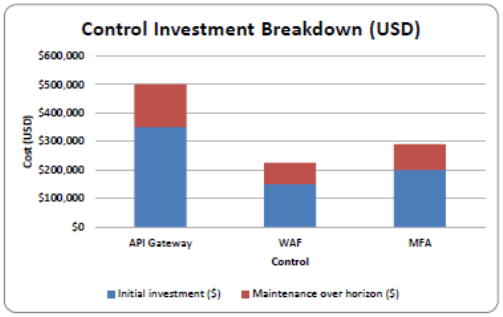
Rank	Vulnerability	SLE ($)	ARO (per year)	ALE ($ / year)	Priority level
1	F2 – Database Injection Vulnerability	$125,000,000	25%	$31,250,000	Critical
2	F3 – Session Hijacking	$7,500,000	40%	$3,000,000	High
3	F1 – API Authentication Bypass	$5,000,000	15%	$750,000	Medium

Recommended controls (ordered by risk reduction)

Priority	Control	Initial cost ($)	Annual maintenance ($)	Annual risk reduction ($)	Year-1 ROI (%)	Payback (days)	Decision
1	Web Application Firewall (WAF)	$150,000	$25,000	$23,437,500	13,292.9%	2.3	IMPLEMENT
2	Multi-Factor Authentication Enhancement	$200,000	$30,000	$2,850,000	1,139.1%	25.9	IMPLEMENT
3	Advanced API Security Gateway	$350,000	$50,000	$675,000	68.8%	204.4	IMPLEMENT
Total		**$700,000**	**$105,000**	**$26,962,500**	**3,249.4%**	**9.5**	

Year-1 realised benefit with phased roll-out: $24,128,125 loss avoided against $782,917 control spend (net $23,345,208).





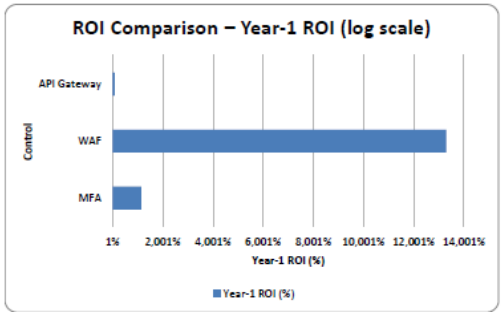


Figure 9: Snapshot of Executive dashboard.

Financial justification

- Total investment: $700,000 initial plus $105,000 a year maintenance = $805,000 in Year 1.
- Steady-state benefit: $26,962,500 per year of avoided expected loss (77.0% of $35,000,000).
- Portfolio Year-1 ROI = ($26,962,500 − $805,000) ÷ $805,000 = 3,249.4%.
- Portfolio payback = $700,000 ÷ ($26,962,500 − $105,000) = 0.026 years ≈ 9.5 days.
- Realistic Year 1 with phased go-live: $24,128,125 loss avoided against $782,917 spend, a net benefit of $23,345,208.
- Residual risk after all three controls is $8,037,500 per year, of which $7,812,500 is the database finding. It should be tracked on the risk register and addressed by root-cause code fixes (Gantt tasks 10 and 12).

Task 7: Risk treatment plan and Gantt chart

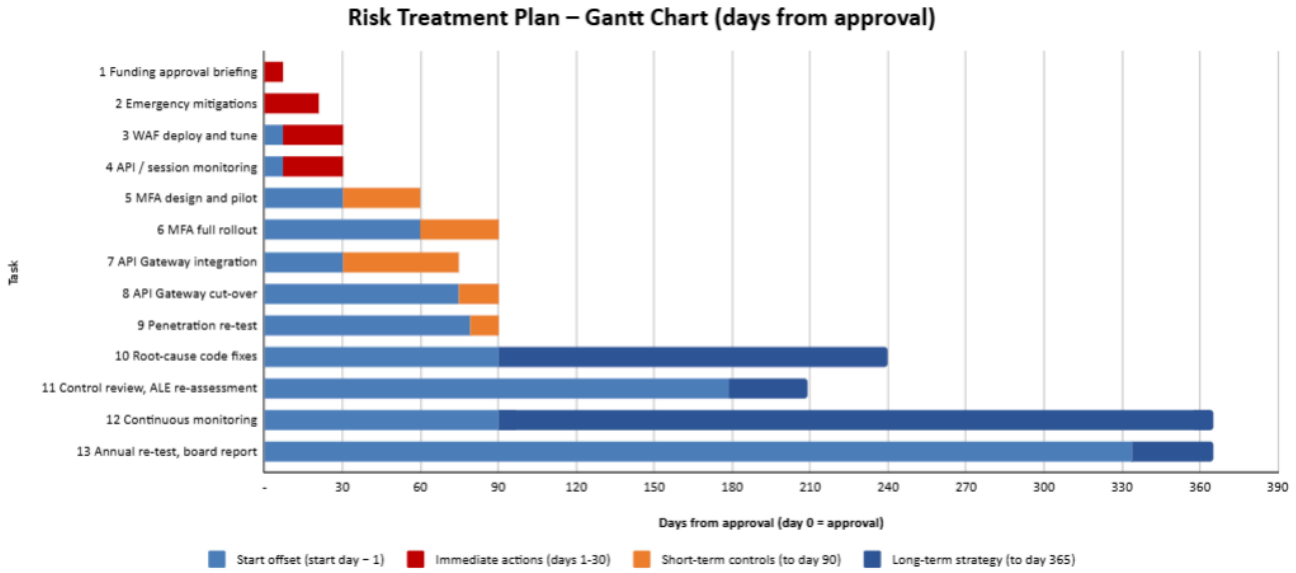


Figure 10: Risk treatment Gantt chart – immediate (days 1-30), short-term (to day 90) and long-term (to day 365).

#	Phase	Task	Start	End	Owner
1	1 Immediate (days 1-30)	Risk acceptance briefing and funding approval (CISO / CFO)	1	7	CISO / CFO
2	1 Immediate (days 1-30)	Emergency mitigations: session timeout & token rotation, API auth hotfix review, input validation rules	1	21	App Sec / DevOps
3	1 Immediate (days 1-30)	WAF procurement, deployment and tuning (virtual patch for database injection)	8	30	Infrastructure / SecOps
4	1 Immediate (days 1-30)	Enhanced API and session monitoring and alerting (shorten 48-hour detection)	8	30	SOC
5	2 Short-term (days 31-90)	MFA enhancement: design, procurement and pilot	31	60	IAM team
6	2 Short-term (days 31-90)	MFA enhancement: full rollout to all customers	61	90	IAM / Mobile team
7	2 Short-term (days 31-90)	API Security Gateway: procurement and integration	31	75	Platform / App Sec
8	2 Short-term (days 31-90)	API Security Gateway: cut-over and acceptance testing	76	90	Platform / QA
9	2 Short-term (days 31-90)	Penetration re-test of the three critical findings	80	90	Red team / third party
10	3 Long-term (days 91-365)	Root-cause remediation in code (parameterised queries, session management, API auth design)	91	240	Engineering
11	3 Long-term (days 91-365)	Control effectiveness review and ALE re-assessment	180	209	GRC
12	3 Long-term (days 91-365)	Continuous monitoring, quarterly testing and risk register updates	91	365	GRC / SOC
13	3 Long-term (days 91-365)	Annual re-test and board report on residual risk	335	365	CISO / GRC

Task dates and owners are planning assumptions (A-13). WAF go-live is the end of task 3 (day 30); MFA go-live is the end of task 6 and API Gateway go-live is the end of task 8 (both day 90).

7. Assumption register (supplied versus assumed)

ID	Assumption	Effect if wrong
A-01	Each supplied 'exploit probability' is the probability of one exploitation event in a 12-month period, so ARO = that probability.	ARO and every ALE scale proportionally (see Sensitivity).
A-02	Finding 1 SLE = the supplied maximum single-incident loss ($5,000,000) × 1 incident. The 48-hour detection time is context and is not used to derive a different loss.	If actual loss per event is lower, ALE and API Gateway ROI fall (see Sensitivity table 3).
A-03	Finding 2 SLE = 500,000 records × $250 = full-population breach in one event.	A smaller breach lowers ALE; WAF stays justified at very low scales (Sensitivity table 2).
A-04	Finding 3 SLE = 5,000 accounts × $1,500 = all at-risk accounts compromised in one event.	Smaller compromise lowers ALE proportionally.
A-05	Control mapping: API Gateway → Finding 1; WAF → Finding 2; MFA → Finding 3. No control reduces any other finding.	Cross-benefits would raise risk reduction and ROI.
A-06	Effectiveness is applied as a proportional reduction of the finding's ALE (lower likelihood); SLE is unchanged.	If effectiveness only partly applies, reduction and ROI fall proportionally.
A-07	Year-1 cost = initial investment + one year of maintenance. Costs are not discounted, inflated, taxed or given a residual value. Maintenance is paid every year from go-live.	Discounting would slightly lower multi-year ROI.

ID	Assumption	Effect if wrong
A-08	ROI = (benefit − cost) ÷ cost. Payback = initial investment ÷ (annual risk reduction − annual maintenance), assuming a constant annual benefit.	Benefit is probabilistic, so realised payback may vary.
A-09	Decision hurdle: 'Implement' if payback ≤ 1 year AND ROI over the 3-year horizon ≥ 100%.	Changing the hurdle can change the recommendation column.
A-10	Risk priority bands: Critical ≥ $10M ALE, High ≥ $1M, Medium ≥ $100k, else Low. Probability: High ≥ 30%, Medium ≥ 10%. Impact (SLE): High ≥ $10M, Medium ≥ $1M.	Different thresholds can change labels but not the ALE ranking.
A-11	Timeline: controls go live when their deployment tasks finish on the Gantt chart (WAF day 30; MFA and API Gateway day 90), protect from the following month, 30 days = 1 month, effectiveness constant.	Slower delivery delays Year-1 benefit.
A-12	Customers (500,000), average transaction ($2,500) and daily transactions (50,000) are context. They are not used in ALE because the brief supplies finding-specific loss figures.	None on the calculations.
A-13	Gantt task start days, durations and owners are analyst planning estimates.	Dates move; costs and ALE do not.
A-14	Budget optimiser compares capital (initial) cost only and tests all 8 combinations of the 3 controls.	Including maintenance in the budget would tighten feasibility.

8. Workbook map

Open the workbook and follow the blue (supplied) and yellow (assumed) cells. Black cells are formulas on the same sheet; green cells pull from another sheet.

- **Inputs:** every supplied figure and assumption
- **Risk_Calc:** SLE, ARO, ALE with the working written out
- **Risk_Matrix:** priority levels and heat map
- **Control_Analysis:** the step-by-step cost-benefit table in Section 4
- **Timeline:** monthly risk reduction data
- **Gantt:** treatment plan with live bars
- **Budget_Optimiser / Sensitivity:** bonus analysis
- **Charts / Dashboard:** native Excel charts and one-page dashboard